

REPORT DI MALWARE ANALISYS

INTRODUZIONE

Questo report documenta l'analisi statica di tre campioni malware reali, caricati su VirusTotal e analizzati attraverso le informazioni di detection, le caratteristiche comportamentali e i tag associati. L'obiettivo dell'esercizio e' quello di familiarizzare con le tecniche di base dell'analisi Blue Team: identificazione della tipologia di minaccia, comprensione del vettore di attacco e valutazione del livello di pericolosita'.

I tre campioni analizzati sono:

- **Sample 1:** Kakwa.doc - Documento Word con macro VBA offuscata (Trojan Downloader)
- **Sample 2:** PCToaster.exe - Eseguibile Java con capacita' di code injection e distruzione dati (KillDisk)
- **Sample 3:** FreePowerPoint.exe.exe - Eseguibile che sovrascrive l'MBR e cifra i file (Ransomware MBRlock)

L'analisi e' stata condotta esclusivamente in modalita' statica tramite VirusTotal, senza esecuzione diretta dei campioni in ambiente controllato. Per ciascun sample vengono riportati: hash SHA-256, detection ratio, vendor di riferimento, tag comportamentali e considerazioni tecniche.

SAMPLE 1 - KAKWA.DOC (TROJAN DOWNLOADER CON MACRO VBA)

INFORMAZIONI GENERALI

Nome file	Kakwa.doc
SHA-256	31ca294ddd253e4258a948cf4d4b7aaaa3e0aa1457556e0e62ee53c22b4eb6f0
Tipo file	Document (DOC) - Microsoft Word
Dimensione	72.00 KB
Detection ratio	45 / 61 vendor
Ultima analisi	13 giorni fa (rispetto al 02/06/2026)
Popular label	TrojanDownloader:O97M/Obfuse.YA (Microsoft)
Community Score	-10

Figura 1 - Scheda riepilogativa del campione Kakwa.doc su VirusTotal

DETECTION E CLASSIFICAZIONE

Il campione e' stato rilevato da 45 vendor su 61 come malevolo. La maggior parte dei motori lo classifica come Trojan downloader basato su macro VBA offuscata per documenti Office (formato O97M). Di seguito alcuni vendor significativi:

Vendor	Rilevazione
Microsoft	TrojanDownloader:O97M/Obfuse.YA!MTB
TrendMicro	Trojan.O97M.POWLOAD.0NA103JI23
ESET-NOD32	GenScript.IOM Trojan
Kaspersky	HEUR:Trojan.MSOffice.SAgent.gen
Avast / AVG	Script:SNH-gen [Drp]
DrWeb	Exploit.Siggen2.4960
SentinelOne (ML)	Static AI - Malicious OLE
Symantec	ISB.Downloader!gen69
VBA32	TrojanDownloader.O97M.Obfuse.YA
Cynet	Malicious (score: 99)

Figura 2 - Selezione dei vendor che rilevano Kakwa.doc come malevolo

TAG COMPORTAMENTALI

VirusTotal associa al campione i seguenti tag, che descrivono le capacita' tecniche osservate durante l'analisi statica e dinamica del documento:

- doc - formato documento Office legacy
- long-sleeps - il codice utilizza sleep prolungati per eludere sandbox con timeout brevi
- obfuscated - presenza di offuscamento nel codice macro
- executes-dropped-file - il documento scarica ed esegue un file esterno
- detect-debug-environment - tecniche anti-analisi per rilevare ambienti virtuali o debugger
- create-ole - creazione di oggetti OLE, tipicamente usata per eseguire script tramite COM
- macros - presenza confermata di macro VBA
- run-file - esecuzione diretta di file dal disco
- auto-open - la macro si attiva automaticamente all'apertura del documento
- calls-wmi - utilizzo di Windows Management Instrumentation per eseguire comandi di sistema

ANALISI TECNICA DEL CODICE MACRO

VirusTotal fornisce un'analisi dettagliata del codice macro contenuto nel documento. La funzione principale, denominata `Document_Open()`, viene eseguita automaticamente all'apertura del file e richiama una subroutine offuscata nel modulo `qpnzeyiw`.

Il meccanismo di offuscamento si basa su una funzione di decodifica chiamata `gtkwfbl`, che riceve in input una stringa di numeri separati da spazi, sottrae 30 da ciascun valore numerico e converte il risultato nel carattere ASCII corrispondente tramite la funzione `Chr()`. Il risultato è una stringa che viene costruita dinamicamente a runtime, rendendo il codice illeggibile a un'analisi statica superficiale.

```
Set cjthojrace_nd = CreateObject(t_odyuhiud_a_rw_ubx_frp)
cjthojrace_nd.Run kcup, lmzu_dqpfyqmp
```

La stringa decodificata viene usata per creare un oggetto tramite `CreateObject()`, che con ogni probabilità risolve a uno shell host (`WScript.Shell` o simile). L'oggetto viene poi utilizzato per eseguire un comando contenuto nella variabile `kcup`, costruita concatenando le stringhe decodificate. Questo pattern è tipico dei downloader che scaricano ed eseguono payload di secondo stadio da URL remoti.

Hispasec (sandbox integrata in VirusTotal) classifica il campione come *malicious*, evidenziando:

- Offuscamento pesante tramite la funzione `gtkwfbl`
- Creazione dinamica di oggetti COM potenzialmente pericolosi
- Esecuzione di contenuto decodificato a runtime
- Possibili meccanismi di persistenza attraverso le azioni eseguite
- Disabilitazione potenziale degli avvisi di sicurezza macro

VETTORE DI ATTACCO E RISCHIO

Il vettore di attacco è il phishing via documento Office. La vittima riceve un file `.doc` apparentemente legittimo, lo apre e, se le macro sono abilitate, il codice si esegue silenziosamente in background. Il documento sfrutta l'`auto-open` per garantire l'esecuzione senza interazione ulteriore da parte dell'utente.

Il livello di rischio è alto. Il campione combina tecniche di evasione (`sleep`, `anti-debug`, `offuscamento`) con capacità di download e persistenza. L'utilizzo di WMI e COM objects lo rende efficace anche su sistemi con policy di sicurezza parziali.

SAMPLE 2 - PCTOASTER.EXE (TROJAN JAVA/CRYPTINJECT + KILLDISK)

INFORMAZIONI GENERALI

Nome file	PCToaster.exe
SHA-256	85a58aa96dccc94316a34608ba996656a22c8158d5156b6e454d9d69e6ff38c3

Tipo file	PE32 Executable (EXE) - Windows
Dimensione	411.82 KB
Detection ratio	46 / 70 vendor
Ultima analisi	18 giorni fa (rispetto al 02/06/2026)
Popular label	trojan.java/cryptinject
Threat categories	trojan, ransomware, virus
Family labels	java, cryptinject, killdisk
Community Score	-70

Figura 4 - Scheda riepilogativa di PCToaster.exe su VirusTotal

DETECTION E CLASSIFICAZIONE

PCToaster.exe e' il campione con il community score piu' negativo (-70), indicatore di una percezione di alta pericolosita' da parte della community di VirusTotal. Viene rilevato da 46 vendor su 70. Le label assegnate coprono tre categorie di minaccia: trojan, ransomware e virus, con due famiglie principali identificate: CryptInject e KillDisk.

Vendor	Rilevazione
Microsoft	Trojan:Win32/CryptInject!MSR
CrowdStrike Falcon	Win/malicious_confidence_100% (W)
Kaspersky	Trojan.Java.Agent.oi
ESET-NOD32	Generik.MHFMXPU Trojan
K7AntiVirus / K7GW	Ransomware (005cf67a1)
VirIT	Trojan.Win32.KillDisk.UVE
NANO-Antivirus	Trojan.Win32.KillDisk.evwiq

Malwarebytes	Neshta.Virus.FileInfector.DDS
Yandex	Trojan.KillDisk!3CDSYus7w0U
DrWeb	Trojan.KillDisk.14070

Figura 5 - Selezione dei vendor che rilevano PCToaster.exe come malevolo

TAG COMPORTAMENTALI

I tag assegnati a questo campione rivelano un profilo tecnico particolarmente aggressivo:

- peexe - eseguibile PE Windows confermato
- calls-wmi - interazione con Windows Management Instrumentation
- direct-cpu-clock-access - accesso diretto all'hardware, tecnica usata per rilevare ambienti virtualizzati
- checks-usb-bus - enumerazione dei dispositivi USB connessi
- detect-debug-environment - anti-analisi, rileva la presenza di debugger o sandbox
- checks-disk-space - verifica dello spazio disco disponibile
- checks-user-input - monitora l'attività dell'utente
- runtime-modules - caricamento di moduli a runtime, tipico dell'injection
- overlay - presenza di dati nell'overlay del PE, spesso usata per nascondere payload

ANALISI TECNICA

Il nome 'PCToaster' (letteralmente 'brucia il PC') è un chiaro riferimento alla funzionalità distruttiva del campione. L'accostamento delle famiglie CryptInject e KillDisk suggerisce un malware a doppia funzione: da un lato esegue code injection per compromettere processi legittimi e iniettare codice malevolo, dall'altro implementa funzionalità tipiche di KillDisk, che sovrascrive file di sistema e può rendere il sistema non avviabile.

Il fatto che K7AntiVirus e K7GW lo classifichino come Ransomware suggerisce che il campione possa anche cifrare i dati della vittima prima di procedere alla distruzione, massimizzando il danno. L'accesso diretto al clock della CPU e l'enumerazione USB indicano tecniche di fingerprinting dell'ambiente, probabilmente per evitare l'esecuzione in sandbox e colpire solo sistemi fisici reali.

La presenza di un overlay nel file PE è un indicatore tipico di payload nascosti: il malware può contenere al suo interno un secondo eseguibile o shellcode che viene estratto ed eseguito a runtime, rendendo l'analisi statica più complessa.

VETTORE DI ATTACCO E RISCHIO

Il nome 'PCToaster.exe' è un esempio di social engineering minimale: un utente poco esperto potrebbe essere indotto ad eseguire il file credendolo un tool di sistema o un utility software. Il livello di rischio è critico: il campione combina injection, possibile cifratura dei dati e capacità distruttive di tipo KillDisk, che possono rendere il sistema permanentemente inutilizzabile senza un recupero da backup.

SAMPLE 3 - FREEPOWERPOINT.EXE.EXE (RANSOMWARE MBRLOCK/MBRO)

INFORMAZIONI GENERALI

Nome file	FreePowerPoint.exe.exe
SHA-256	9c3f8df80193c085912c9950c58051ae77c321975784cc069ceacd4f57d5861d
Tipo file	PE32 Executable (EXE) - Windows
Dimensione	136.00 KB
Detection ratio	62 / 70 vendor
Ultima analisi	26 giorni fa (rispetto al 02/06/2026)
Popular label	trojan.mbro/mbrlock
Threat categories	trojan, ransomware
Family labels	mbro, mbrlock, hiamoe
Community Score	-54

Figura 6 - Scheda riepilogativa di FreePowerPoint.exe.exe su VirusTotal

DETECTION E CLASSIFICAZIONE

FreePowerPoint.exe.exe e' il campione con il detection ratio piu' alto: 62 vendor su 70 lo classificano come malevolo. La doppia estensione .exe.exe e' un classico indicatore di tentativo di inganno: su sistemi Windows con estensioni nascoste, il file potrebbe apparire come 'FreePowerPoint.exe', facendolo sembrare un eseguibile legittimo. La famiglia MBRlock e' nota per sovrascrivere il Master Boot Record del disco, rendendo il sistema impossibile da avviare.

Vendor	Rilevazione
Microsoft	Ransom:Win32/Genasom.DV
CrowdStrike Falcon	Win/malicious_confidence_100% (W)
TrendMicro	TROJ_RANSOM_BL13015C.TOMC

Avast / AVG	MBR:Ransom-A [Rtk]
Rising	Ransom.MBRlock!1.66BD (CLASSIC)
Sangfor Engine Zero	Ransom.Win32.Mbrlock_2.se2
ESET-NOD32	Win32/MBRlock.R Trojan
Varist	W32/ABRansom.SRXZ-2599
Trellix ENS	Ransom-FVO!70108103A531
Cynet	Malicious (score: 99)

Figura 7 - Selezione dei vendor che rilevano FreePowerPoint.exe.exe come malevolo

TAG COMPORTAMENTALI

I tag di questo campione indicano un comportamento particolarmente aggressivo a livello di sistema:

- peexe - eseguibile PE Windows
- self-delete - il file si elimina dopo l'esecuzione per ostacolare la forensics
- executes-dropped-file - scarica ed esegue componenti aggiuntivi
- checks-disk-space - verifica lo spazio disponibile prima di operare
- checks-user-input - monitora l'input utente, possibile keylogging
- via-tor - comunicazioni attraverso la rete Tor per anonimizzare il C2
- detect-debug-environment - anti-analisi contro sandbox e debugger

ANALISI TECNICA

L'MBRlock e' una delle forme di ransomware piu' distruttive perche' non si limita a cifrare i file dell'utente ma interviene direttamente sul Master Boot Record del disco rigido. Il MBR e' il settore di avvio del disco che contiene le istruzioni necessarie per caricare il sistema operativo. Sovrascrivendolo con un messaggio di riscatto, il malware rende il computer completamente inutilizzabile al riavvio: al posto di Windows, l'utente si trova davanti a una schermata con le istruzioni per il pagamento.

Il tag via-tor indica che il malware utilizza la rete Tor per comunicare con il suo server di Command & Control (C2), rendendo estremamente difficile tracciare l'origine dell'attacco o bloccare le comunicazioni tramite semplice firewall basato su IP. Il self-delete garantisce che, dopo aver compromesso il sistema, non rimanga traccia dell'eseguibile originale sul disco.

La doppia estensione .exe.exe e' una tecnica di ingegneria sociale semplice ma efficace: su Windows con le estensioni dei file nascoste (impostazione predefinita), il file apparira' come 'FreePowerPoint.exe', portando l'utente a credere di aprire un installer legittimo per PowerPoint gratuito.

VETTORE DI ATTACCO E RISCHIO

Il vettore di attacco primario e' il download da fonte non fidata, sfruttando la promessa di software commerciale gratuito. La vittima scarica quello che crede essere un installer di PowerPoint, lo esegue e il sistema viene compromesso immediatamente. Il livello di rischio e' critico: la sovrascrittura dell'MBR combinata con la cifratura dei file rende il recupero dei dati praticamente impossibile senza un backup aggiornato. La comunicazione via Tor rende inoltre difficile qualsiasi intervento di blocco a livello di rete.

ANALISI COMPARATIVA

La tabella seguente mette a confronto i tre campioni analizzati rispetto alle caratteristiche principali, per avere una visione d'insieme del panorama di minacce esaminato.

Caratteristica	Kakwa.doc	PCToaster.exe	FreePowerPoint.exe.exe
Tipo file	DOC (Office)	PE32 EXE	PE32 EXE
Dimensione	72 KB	411.82 KB	136 KB
Detection ratio	45/61 (73.8%)	46/70 (65.7%)	62/70 (88.6%)
Community Score	-10	-70	-54
Tipologia	Trojan Downloader	Trojan/KillDisk	Ransomware MBRlock
Vettore	Phishing documento	Social engineering	Download software pirata
Anti-analisi	Si (debug, sleep)	Si (debug, cpu clock)	Si (debug, self-delete)
Rete C2	Probabile HTTP/S	Non specificato	Via Tor
Rischio	Alto	Critico	Critico

Tabella 1 - Confronto comparativo dei tre campioni malware analizzati

CONCLUSIONI

L'analisi dei tre campioni ha permesso di identificare tre tipologie di minaccia distinte ma complementari, che rappresentano bene la varietà del panorama attuale del malware:

Kakwa.doc rappresenta la minaccia più subdola: si presenta come un normale documento Word e sfrutta le macro per scaricare payload aggiuntivi. È il classico strumento di accesso iniziale usato nelle campagne di phishing. La sua rilevabilità è media (73.8%) proprio perché il payload reale viene scaricato dopo l'infezione, rendendo il file stesso apparentemente innocuo per alcuni motori.

PCToaster.exe è la minaccia più polivalente: combina injection, possibile cifratura e capacità distruttive di tipo KillDisk. Il nome stesso è una dichiarazione di intenti. Il community score di -70 è il più basso del gruppo, segno che chi ha analizzato il file lo considera particolarmente pericoloso.

FreePowerPoint.exe.exe è il campione più facilmente rilevabile (88.6% di detection) ma anche il più distruttivo per l'utente finale. La sovrascrittura dell'MBR rende il sistema inutilizzabile al riavvio successivo, e la comunicazione via Tor rende difficile qualsiasi contromisura a livello di rete.

INDICATORI DI COMPROMISSIONE (IOC)

Di seguito gli hash SHA-256 dei campioni analizzati, utilizzabili come IoC per il rilevamento:

```
31ca294ddd253e4258a948cf4d4b7aaaa3e0aa1457556e0e62ee53c22b4eb6f0 [Kakwa.doc]
85a58aa96ccd94316a34608ba996656a22c8158d5156b6e454d9d69e6ff38c3 [PCToaster.exe]
9c3f8df80193c085912c9950c58051ae77c321975784cc069ceacd4f57d5861d [FreePowerPoint.exe.exe]
```

RACCOMANDAZIONI DIFENSIVE

- Disabilitare l'esecuzione automatica delle macro Office nei criteri di gruppo (Group Policy)
- Implementare soluzioni EDR in grado di rilevare comportamenti anomali a runtime, non solo firme statiche
- Bloccare il traffico verso la rete Tor a livello di firewall perimetrale
- Mantenere backup offline regolari per mitigare gli effetti di ransomware MBR-based
- Formare gli utenti sul rischio di file con doppia estensione e di software scaricato da fonti non ufficiali
- Monitorare le chiamate WMI e le creazioni di oggetti COM inusuali tramite SIEM

Questa analisi ha dimostrato come strumenti pubblici come VirusTotal rappresentino un punto di partenza fondamentale per l'analista Blue Team: anche senza eseguire direttamente i campioni in sandbox, i tag comportamentali, le label dei vendor e il community score forniscono informazioni sufficienti per classificare la minaccia e definire le contromisure appropriate.